

RESTARTING

BIOHACKING WEARABLES



5

LISTA DE FIGURAS

Figura 1 – <i>User Agent</i>	6
Figura 2 - Utilização de servidor proxy	8
Figura 3 - O protocolo SOCKS no modelo OSI	10
Figura 4 - Elementos da Rede Tor	10
Figura 5 - Criptografia em camadas na rede Tor.....	12
Figura 6 - <i>Mindmap</i> de ações em OSINT	20
Figura 7 - Maltego	21
Figura 8 - Recon-NG	23
Figura 9 - The Harvester rodando o Kali Linux.....	23
Figura 10 - Shodan.....	24
Figura 11 - Extração do Tor <i>Browser</i>	27
Figura 12 - Conectando na Rede Tor.....	28
Figura 13 - Usando o Tor Browser	28

SUMÁRIO

ANONIMIZAÇÃO E <i>OPEN SOURCE INTELLIGENCE</i>	4
1 INTRODUÇÃO	4
2 PRIVACIDADE DOS USUÁRIOS.....	4
3 POR QUE ANONIMIZAR?	4
4 IDENTIFICANDO A ORIGEM DO TRÁFEGO	5
5 ESCONDENDO-SE NA REDE.....	8
6 ALTERANDO O <i>USER AGENT</i>	8
7 PROXY.....	8
8 REDE TOR.....	9
9 VPS	13
10 VPN	14
11 CRIPTOMOEDA OU MOEDA VIRTUAL	14
11.1 <i>Bitcoin e Blockchain</i>	14
12 <i>OPEN SOURCE INTELLIGENCE (OSINT)</i>	16
13 METODOLOGIA PARA AÇÕES DE OSINT.....	18
14 OSINT E ANONIMIZAÇÃO	20
15 TOP 5 FERRAMENTAS DE OSINT	21
16 LAB	26
16.1 Contexto	26
16.2 Informações iniciais sobre o alvo	26
16.3 Condução do LAB	26
REFERÊNCIAS.....	30

ANONIMIZAÇÃO E OPEN SOURCE INTELLIGENCE

1 INTRODUÇÃO

Anonimização e OSINT são dois termos que você já deve ter ouvido falar. Agora, terá um capítulo destinado somente para esses dois conceitos. Você verá como é importante manter-se anônimo em muitas situações, por exemplo, para aqueles que querem testar uma defesa passando despercebidos pelo “*Blue Team*”, mas com certeza verá mais aplicações após a leitura deste conteúdo.

2 PRIVACIDADE DOS USUÁRIOS

Nos primórdios da internet, a privacidade dos usuários era algo comum; na realidade, não se pensava em outra forma de se utilizar a rede mundial. Nessa época, os primeiros fóruns e salas de bate-papo, por exemplo, não cobravam dos usuários seus dados básicos de acesso, como endereço IP, tipo de navegador e sistema operacional. No entanto, por meio do fomento do uso das publicidades massivas na rede, percebeu-se o poder que mecanismos de identificação dos usuários, como os cookies, teriam para potencializar as publicidades direcionadas. Quem nunca ouviu a expressão “na internet, se você não consome um produto, você é o produto”?

E, nesse escopo caótico de abusos de privacidade em que a internet tem se inserido, trabalhar como analista de inteligência pode ser uma tarefa um tanto arriscada, uma vez que não é trivial se manter anônimo na rede.

3 POR QUE ANONIMIZAR?

Do ponto de vista da inteligência, um profissional de defesa cibernética jamais deve se expor no ciberespaço, uma vez que frequentemente realizará atividades de caráter investigativo e/ou exploratório. Ter sua identidade real, além de informações, como endereço IP, *user agent* do *browser* e sistema operacional, acessíveis ao alvo pode resultar em sérios problemas para o profissional.

Imagine um cenário onde você, analista de defesa cibernética, recebe a tarefa de explorar vulnerabilidades do site de uma filial da sua empresa, sem que os integrantes do time de segurança saibam que estão sendo testados. Esse teste será realizado para identificar, além de brechas de segurança, a execução do trabalho de proteção cibernética que esse time deveria estar realizando nos ativos da filial. Dentro desse escopo, não basta ser um exímio *pentester* – profissional que realiza ações cibernéticas ofensivas com o intuito de descobrir vulnerabilidades – se não souber realizar uma anonimização adequada, pois o sucesso da tarefa depende primordialmente de não ser descoberto.

De posse dos conceitos até agora abordados, poderíamos inferir que anonimizar seria estar indetectável no mundo cibernético? Não. A anonimização consiste em dificultar a autoria de um determinado tráfego de dados. Ela é a “kriptonita” do analista de incidentes de rede, já que o objetivo do seu trabalho é, basicamente, identificar o autor de um evento ou incidente cibernético. No entanto, por meio da anonimização, essa identificação torna-se difícil de ser confirmada, levando o analista de incidentes a fazer inferências com base em erros, de maneira que o verdadeiro autor das ações quase sempre permanece desconhecido.

4 IDENTIFICANDO A ORIGEM DO TRÁFEGO

Existem algumas formas de garantir a autoria de uma ação cibernética baseada nas seguintes tecnologias:

a) IP

A rede mundial de computadores é baseada em protocolo TCP/IP. As faixas de IP disponíveis e seus respectivos donos (ou responsáveis) são gerenciados pela IANA (*Internet Assigned Numbers Authority*). Desse modo, o IP que seu ISP (*Internet Service Provider*) lhe disponibilizou (mesmo que de forma dinâmica) é de conhecimento do mundo todo. Não apenas ele, mas também os dados relacionados a ele, como a origem e o nome do ISP. Portanto, realizar uma ação de inteligência cibernética utilizando seu IP real não é aconselhável.

b) User Agent

Quando solicitamos uma página *web*, o nosso *browser* envia uma série de cabeçalhos para o servidor. Cada cabeçalho contém detalhes que ajudam o servidor a determinar a melhor maneira de fornecer a informação solicitada. A sequência do *user agent* pode conter detalhes opcionais chamados *tokens*, que devem ser colocados entre parênteses e que variam entre os diferentes programas. O *Internet Explorer* utiliza símbolos para descrever detalhes adicionais sobre o seu computador.

A figura “User Agent” mostra um exemplo enviado pelo *Internet Explorer* e que destaca os *tokens*.

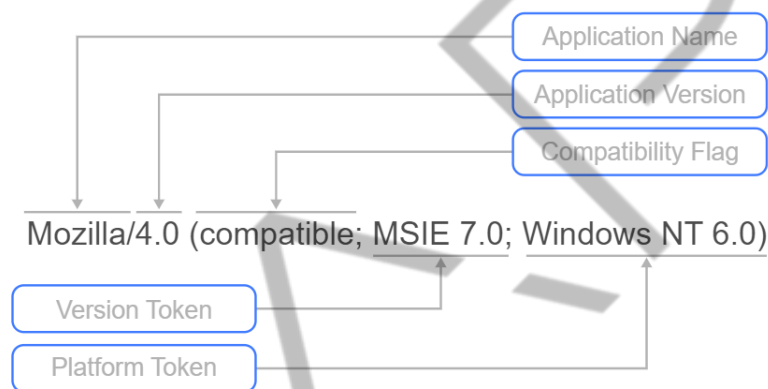


Figura 1 – User Agent
Fonte: PPLWare (2019)

A *string user agent* contém três *tokens*:

- A flag *compatibility* é usada pela maioria dos *browsers* mais modernos. Ela indica que o *Internet Explorer* é compatível com um conjunto comum de características.
- O *token version* identifica o *browser* e contém o número da versão. A versão *token* no exemplo (“MSIE 7.0”) identifica o *Internet Explorer* 7.
- O *token platform* identifica o sistema operacional e contém o número da versão. Esse *token*, no exemplo, (“Windows NT 6.0”) indica o *Windows Vista*.

Dessa forma, compartilhar seu *user agent* verdadeiro com o alvo não é uma boa opção, visto que dados importantes serão expostos.

c) Cookies

Os *cookies* são pequenos arquivos armazenados temporariamente nos navegadores e que compartilham o que o internauta está visitando na rede. Não há limite para quais informações os *cookies* podem armazenar, podendo ser um endereço de e-mail, as preferências de pesquisa no Google, a cidade de onde você está conectado, os sites que você visitou anteriormente, credenciais de acesso a um determinado site e muito mais. E é justamente essa capacidade de registro que pode tornar o *cookie* um grande vilão.

d) Geolocalização

Muitos sites atualmente utilizam a localização do usuário para lhe fornecer conteúdo personalizado e alguns navegadores modernos e sistemas operacionais já fornecem isso aos sites, mesmo que você não autorize.

Quando falamos em anonimização, a geolocalização é um ponto crucial de cuidado, uma vez que ela pode colocar em risco todo o cuidado prévio que o analista teve de ofuscar seu IP.

e) Correlação de tráfego

Apesar de ser subjetiva, a correlação de tráfego é amplamente utilizada por analistas de incidentes de rede para tentar identificar acessos anonimizados.

Imagine que você necessite realizar alguma ação em determinado site e, antes de realizá-la, decida visitar o site para testar suas funcionalidades. Porém, durante os testes, você identifica uma possível vulnerabilidade em determinada página e decide atacar. A partir deste momento, você utiliza as técnicas de anonimização para realizar sua ação e, após realizá-la, você pode “desanonimizar” sua conexão e acessar novamente o site para ver se a sua ação teve êxito.

Até aí tudo ok, certo? Não. Dado o fato de você ter realizado acessos legítimos enviando seu *fingerprint*, ou seja, sua impressão digital online (dados como IP, *user-agent*, cookies etc.) antes e depois do ataque, o analista de incidentes consegue identificá-lo como o possível atacante.

5 ESCONDENDO-SE NA REDE

Até agora, aprendemos como os sites e sistemas nos conhecem na internet. Mas o que devemos fazer para não sermos identificados? Quais são as técnicas de anonimização que podemos utilizar? Vamos descobrir!

6 ALTERANDO O USER AGENT

Existem algumas formas de se alterar o *user agent* de um *browser*. No entanto, a mais simples é utilizando uma extensão chamada “*User Agent Switcher*”, que está disponível para a maioria dos navegadores. Com ela, é possível fazer o *spoofing* do *browser* e imitar as *strings* de *user agent* de outros navegadores e sistemas operacionais, tudo isso com apenas alguns cliques.

7 PROXY

Servidores proxy são uma espécie de ponte, ou *gateway*, entre você e o destino. Por meio deles é possível que o dado trafegado chegue ao destino mascarando sua origem, uma vez que o acesso terá sido feito ao destino pelo servidor proxy e não pela sua máquina.

Como funciona um servidor Proxy

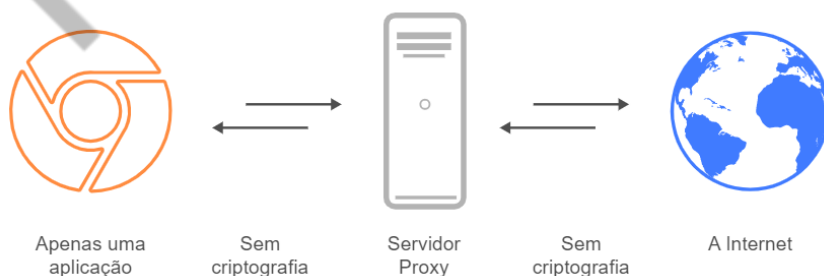


Figura 2 - Utilização de servidor proxy
Fonte: Adaptado por Fiap (2019)

Para utilizar um proxy para anonimizar uma conexão, basta alterar as propriedades de proxy do seu navegador com um endereço de proxy válido, que pode ser um pago ou gratuito disponível na internet. Porém, cabe ressaltar que uma das *features* de um proxy é realizar cache de acessos, ou seja, independente do serviço de proxy escolhido, saiba que seus acessos são monitorados pela empresa que presta esse serviço. Outro ponto ruim é que os serviços de proxy, na maioria dos casos, não provêm conexão criptografada.

8 REDE TOR

Conforme abordado por Vaz (2018), os parâmetros da rede *Tor* foram apresentados na publicação *TOR: The Second-Generation Onion Route*, de Roger Dingledine, Nick Mathewson e Paul Syverson, em 2004. Segundo os autores: “a *Onion Routing* é uma rede sobreposta distribuída projetada para anonimização de aplicações baseadas em TCP, como navegadores web, SSH (*secure shell*) e mensageiros instantâneos”.

Quando um usuário deseja conectar-se a um sistema remoto através da rede *Tor*, ela estabelece o enlace por meio de um circuito de *Onion Routers* (OR). Para acessar a rede *Tor*, o usuário precisa executar, localmente, um programa chamado *Onion Proxy* (OP), que cuidará da conexão entre o usuário e a rede *Tor*. Cada usuário executa localmente um *software* chamado *Onion Proxy* (OP) para buscar diretórios, estabelecer circuitos por meio da rede e manipular as conexões das aplicações do usuário.

Essa rede foi desenhada para funcionar sobre o protocolo TCP. Para isso, utiliza o protocolo SOCKS, versão 5, que foi definido na RFC 1928, de março de 1996. Esse protocolo permite que exista um intermediário entre os elementos de uma conexão TCP ou UDP. Como podemos observar na figura “O protocolo SOCKS no modelo OSI”, as solicitações de conexão de um usuário são enviadas para um servidor que utiliza o protocolo SOCKS, o qual as reencaminha para o endereço desejado. A resposta do servidor é então enviada de volta para o serviço SOCKS, que a encaminha ao usuário.

Por essa capacidade, o protocolo SOCKS tornou-se a base dos servidores proxy que são amplamente empregados em redes corporativas. A rede *Tor* utiliza esse protocolo pois é suportado pela maioria das aplicações baseadas em TCP e torna desnecessário a criação de soluções próprias.

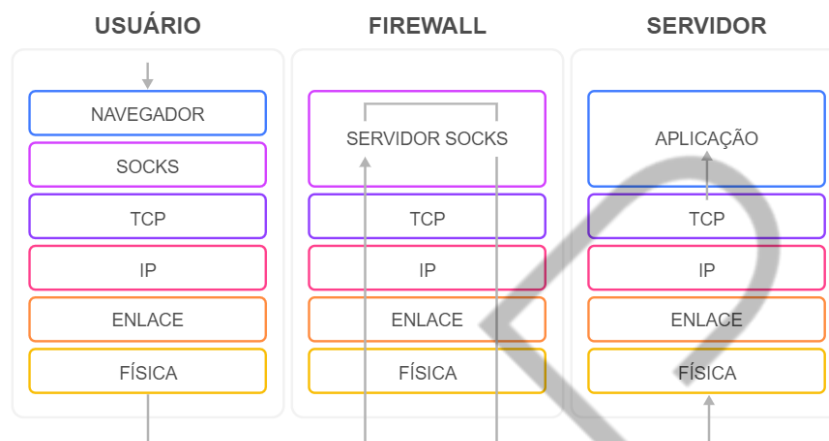


Figura 3 - O protocolo SOCKS no modelo OSI
Fonte: Vaz (2019)

A rede estabelece um circuito formado por três OR, antes de estabelecer a conexão entre o usuário e o destinatário com o qual deseja se conectar. Vamos observar a figura “Elementos da Rede Tor”.

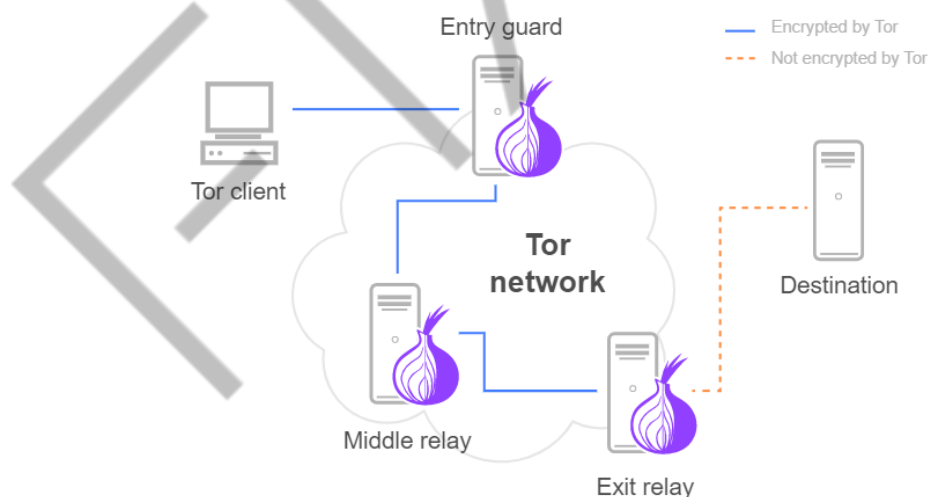


Figura 4 - Elementos da Rede Tor
Fonte: Vaz (2018)

O circuito estabelecido pela rede *Tor* é formado pelos seguintes elementos, conforme Vaz (2018):

1. *Guards*: são os OR com os quais o OP ativado pelo usuário conecta-se. São responsáveis por conectar o cliente à rede *Tor*, bem como por retransmitir os dados

para os demais “nós” da rede. Devido à criptografia realizada no cliente, o *Guard* desconhece o endereço final dos dados, restando somente a informação do endereço do próximo nó.

2. *Middle-Relays*: são “nós” intermediários responsáveis por encaminhar o fluxo de dados ao próximo *Relay* ou até um *Exit Relay*.

3. *Exit Relay*: é o OR que se conecta ao endereço solicitado pelo usuário e que descriptografa os dados criptografados pela rede *Tor*. São “nós” responsáveis pela comunicação com o destino final.

Para manter seus usuários anônimos, a rede *Tor* estabelece diversos padrões. Ela busca impedir que a identidade do usuário seja identificada por meio do mascaramento do seu endereço IP, mas também evita que sua localização seja definida e que uma possível análise de tráfego seja realizada, impedindo que um perfil seja traçado.

Por trafegarem por vários OR, os administradores dos sistemas que funcionam como OR poderiam acessar os dados dos usuários, caso trafegassem sem nenhuma criptografia. Se os dados fossem criptografados com uma chave comum a todos os elementos do circuito estabelecido, caso um OR fosse comprometido, ele poderia forçar outro OR a descriptografar os dados e, então, acessar as informações.

Para evitar essas duas situações, o OP executado no sistema computacional do usuário estabelece uma chave simétrica com cada um dos OR que participam do circuito estabelecido. O OP criptografa os dados do usuário com todas as chaves criadas, como se fossem camadas, e cada um dos OR retira uma camada da criptografia utilizando sua respectiva chave. Dessa forma, mesmo que um OR esteja observando os dados de um usuário durante a transmissão de dados, ele terá acesso apenas ao endereço do próximo salto e do local de onde os dados estão vindo, mas não dá origem.

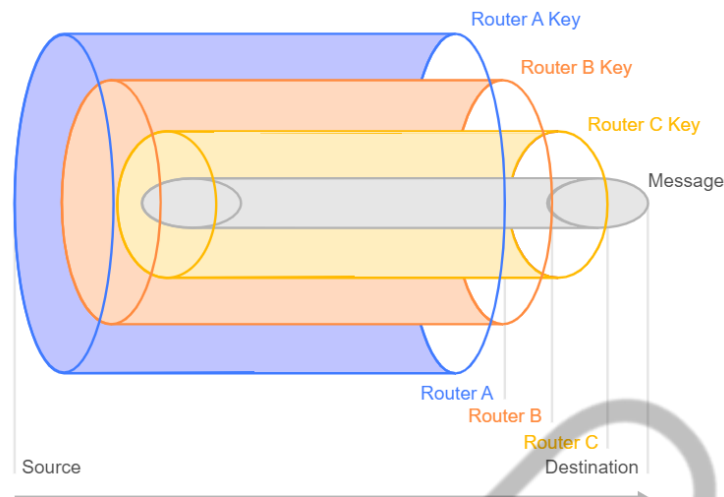


Figura 5 - Criptografia em camadas na rede Tor
Fonte: Vaz (2019)

Como podemos observar na figura “Criptografia em camadas na rede Tor”, as mensagens que trafegam entre o nó de saída (*Exit Relay*) e o servidor não serão criptografadas e poderão ser analisadas caso esse nó seja comprometido. Dessa forma, pode-se inserir mais um nível de segurança utilizando uma conexão segura como o HTTPS ou TLS.

Um circuito pode ser utilizado para transmitir vários *streams* de pacotes TCP. A rede *Tor* multiplexa várias conexões TCP através de um circuito para aumentar a eficiência e anonimidade. Esse comportamento dificulta a identificação de uma única conexão e sua análise, o que poderia identificar o usuário da rede *Tor* por meio de uma análise comportamental.

Para identificar os OR e seus estados atuais, a rede *Tor* utiliza servidores de diretório (*Directory Servers*), os quais são um pequeno número de OR bem conhecidos. Esses servidores disponibilizam a lista dos OR via HTTP e o usuário a utilizará para acessar a rede *Tor* e montar os circuitos de roteadores. Isso evita que algum atacante manipule a criação dos circuitos e direcione os dados de um usuário para um local específico.

Para utilizar a rede *Tor*, basta realizar o download do *Tor Browser* no site do projeto <<https://torproject.org>> e instalá-lo em seu sistema operacional.

9 VPS

Segundo Vaz (2018), um VPS (*Virtual Private Server*) é uma máquina virtual, executada em um computador físico, que será empregada como servidor de algum serviço. O computador físico (hospedeiro) tem seu próprio sistema operacional e um virtualizador gerencia a utilização simultânea de seu *hardware* por todas as máquinas virtuais criadas. Perante a percepção do usuário, uma máquina virtual é igual a um computador físico normal, mas toda a sua estrutura física (memória, armazenamento e periféricos) não existe, pois ela utiliza a do hospedeiro.

Existem, disponíveis na internet, diversos serviços de hospedagem de servidores privados virtuais, nos quais o fornecedor de hospedagem cria um servidor virtual para o cliente, conforme as especificações solicitadas (sistema operacional, quantidade de memória e armazenamento e acesso à internet) e hospeda-o em sua infraestrutura física. O cliente, então, recebe credenciais para acessá-lo remotamente e administrá-lo livremente. Nesse serviço, o cliente é o responsável por gerenciar o servidor criado, além de instalar e manter os serviços que desejar, como faria na configuração de um servidor físico. O fornecedor do serviço de hospedagem, por sua vez, mantém a estrutura física em que o VPS foi instalado e garante que esteja acessível ao cliente.

Como qualquer outra máquina virtual, mesmo sendo executada dentro de um computador, um servidor virtual tem a mesma privacidade de uma máquina física particular. Mesmo compartilhando a mesma estrutura física, não há troca de informações entre o hospedeiro e as máquinas virtuais que forem executadas nele, nem entre uma máquina virtual e outra.

Nesse contexto, um VPS torna-se um excelente vetor de um ataque cibernético, pois é possível contratar o serviço de hospedagem de VPS por meio de criptomoedas e acessar a máquina criada anonimamente, podendo, assim, manter não só o acesso protegido, mas também a identidade do atacante.

Após a realização de ataque ou ação cibernética qualquer, durante as prováveis investigações forenses e análises de incidente, será possível rastrear a origem do ataque, que será o VPS. Ainda que o fornecedor armazene os registros dos proprietários e os dados dos acessos, não será possível identificar o proprietário do

VPS, pois os registros não conterão dados reais e os acessos ao VPS serão realizados por meio da rede *Tor*, além de que o pagamento pelo serviço de hospedagem foi realizado por criptomoedas.

10 VPN

As VPNs são também utilizadas para proteger ou anonimizar um tráfego através de uma conexão não segura (como a internet, por exemplo). Há empresas que provêm este tipo de serviço com o intuito de impedir que os conteúdos do tráfego dos seus clientes sejam armazenados nos ISPs ou sejam capturados por outros usuários, permitindo também esconder a localização geográfica do utilizador, entre outros aspectos.

Esses serviços são populares em relação aos sistemas que envolvem compartilhamento de dados *peer-to-peer* (P2P). Tal atividade é geralmente limitada pelos ISPs por questões de violação de direitos autorais. Nesse contexto, as VPNs podem permitir o tráfego e esconder os verdadeiros endereços de IP nesse tipo de conexão.

11 CRIPTOMOEDA OU MOEDA VIRTUAL

De acordo com Vaz (2018), uma criptomoeda, ou moeda virtual, não tem uma função diferente de moedas tradicionais: representam um valor e são utilizadas para realizar transações comerciais. A diferença é que elas não são controladas ou mantidas por órgãos financeiros ou governos, e não é necessária a intervenção de nenhum agente financeiro, como um banco, na sua circulação. Um usuário realiza a transferência de valores diretamente para outro, sem controle ou ação de nenhum tipo de intermediário.

11.1 *Bitcoin e Blockchain*

Conforme Vaz (2018), o *Bitcoin* é popularmente conhecido como uma criptomoeda, mas utiliza uma série de protocolos e dispositivos que permitem sua

circulação sem nenhum controle central. Ele é um conjunto de conceitos e tecnologias que formam a base de um ecossistema de dinheiro digital. As unidades de moeda chamadas *bitcoins* são usadas para armazenar e transmitir valor entre os participantes na rede *Bitcoin*. Os usuários comunicam-se entre si utilizando o protocolo *bitcoin* principalmente através da Internet, mas outras formas de rede também podem ser usadas. A implementação da pilha do protocolo está disponível como *software* de código aberto e pode ser executada em uma ampla variedade de dispositivos de computação, incluindo laptops e smartphones, o que torna a tecnologia de fácil acesso.

Ainda de acordo com Vaz (2018), o *Blockchain* é o local onde são registradas as operações de *bitcoins* dentro da rede *Bitcoin*. As células de informações (*block*) são conectadas umas às outras (*chains*) conforme as *bitcoins* são criadas ou negociadas. Essas informações são ligadas de forma permanente, motivo pelo qual as transações dessa criptomoeda são irreversíveis. Cada integrante da rede possui uma cópia desse registro e recebe cada atualização (que é realizada seis vezes a cada hora). São esses usuários que validam as transações comparando os dados de cada transação que é realizada com a sua cópia do banco de dados. Essa característica garante transparência a todo o sistema, pois todas as transações são públicas e auditáveis.

As transações realizadas na rede *Bitcoin* são processadas e registradas em um banco de dados semelhante a um livro contábil virtual contínuo, que é o *blockchain*, do qual cada componente da rede possui uma cópia em seu computador, formando uma rede distribuída. Assim, no *blockchain* da rede *Bitcoin* é possível verificar todas as transações já realizadas, desde a primeira, em 2009, uma vez que os registros são contínuos, públicos e rastreáveis.

Essa característica da criptomoeda fez com que ela fosse utilizada para práticas criminosas, como evasão de divisas, comércio ilegal, tráfico de armas e drogas. Infelizmente, o *Bitcoin* rapidamente começou a ganhar uma reputação indesejada. Um exemplo dessa característica foi o ataque do vírus *WannaCry*, ocorrido em 2017. Neste tipo de ataque, um vírus criptografava todos os dados armazenados no computador da vítima, e, para receber a chave que permitia a descriptografia dos arquivos, ela era obrigada a realizar uma transferência de *bitcoins* para um endereço específico.

O responsável por espalhar esse vírus globalmente não se preocupou em ocultar a carteira para a qual o pagamento deveria ser enviado. Entretanto, apesar de a confidencialidade das partes envolvidas em uma transação ser característica da rede *Bitcoin*, sua aquisição ou conversão em moedas fiduciárias ainda envolverá instituições financeiras. Nesse momento, os registros normais de uma transação financeira serão feitos utilizando-se dados de cartões de crédito ou documentos pessoais solicitados. Dessa forma, mesmo que uma das características da rede seja que as partes envolvidas em uma transação não possam ser identificadas, essa forma de aquisição deve ser evitada, como mais uma garantia de anonimato.

12 OPEN SOURCE INTELLIGENCE (OSINT)

Dentre as diversas ações cibernéticas realizadas no campo da inteligência e contrainteligência, estão as ações de coleta de dados no campo cibernético.

Levando em consideração as ações de inteligência na obtenção de dados estudadas anteriormente, podemos categorizar as ações em busca, quando é necessário obter um dado protegido que não está disponível publicamente (uma atividade que geralmente envolve engenharia social, invasão, desenvolvimento e implantação de *malware*, *backdoors*, entre outros), e coleta, que ocorre quando obtemos dados por meio de fontes abertas, ou seja, por meio da exploração cibernética de fontes como redes sociais, mecanismos de busca, etc. Neste capítulo, discutiremos especificamente as ações relacionadas à coleta de dados.

De acordo com Freitas e Costa (2018), na atividade de inteligência, a coleta e obtenção de dados e informações se dá de várias formas. As fontes de inteligência são classificadas de acordo com a natureza e a proveniência dos dados que elas fornecem. Alguns acrônimos são usados para definir esses tipos de inteligência com base na sua forma de obtenção. Os tópicos a seguir trazem uma breve descrição dos principais tipos de fontes de inteligência.

- a) *Human Intelligence* (Inteligência Humana): descreve um tipo de inteligência derivada de informações coletadas e fornecidas por fontes humanas. Obtido por meio de interrogatórios, depoimentos e entrevistas, é o tipo mais básico

de inteligência, pois requer apenas capital humano especializado para a sua coleta e dispensa o alto custo de uma operação de campo.

- b) *Signals Intelligence Measurement and Signatures Intelligence* (Inteligência de medição e assinaturas): é o termo que define a inteligência obtida por meio de medidas e assinaturas de eventos químicos ou físicos, como, por exemplo, de um incêndio.
- c) *Cyber Intelligence/Digital Network Intelligence* (Inteligência Cibernética/Inteligência de Redes Digitais): refere-se à inteligência obtida do ciberespaço. Bastante difundida atualmente, dentro dela inserem-se outros tipos de inteligências.
- d) *Open Source Intelligence* (Inteligência de Fontes Abertas): é definida como inteligência derivada de informações publicamente disponíveis, bem como outras informações não classificadas, isto é, cujo conteúdo não possui caráter sigiloso e pode ser conhecido por qualquer pessoa.

Dessa forma, a OSINT é um modelo de inteligência que visa coletar, processar e analisar informações provenientes de fontes públicas para complementar uma informação e subsidiar a tomada de decisão e planejamento. Esse tipo de inteligência tem se tornado mais importante e expressivo nas últimas décadas, com a expansão dos meios de comunicação, principalmente a rede mundial de computadores. Entretanto, os Estados Unidos, por meio do departamento de OSINT da *Central Intelligence Agency* - CIA, já lida com esse tipo de dado desde a Segunda Guerra Mundial.

Durante a Guerra Fria, o *Foreign Broadcast Information Service* – FBIS (Serviço de Vigilância de Mídia Estrangeira) analisava e traduzia a maioria das publicações técnico-científicas da União Soviética.

Uma das maiores vantagens de usar a OSINT é o custo. Ela é muito mais barata em comparação com as ferramentas tradicionais de coleta de informações e é particularmente relevante para organizações com um orçamento de inteligência limitado. As informações podem ser legais e facilmente compartilhadas com qualquer pessoa, haja vista que as informações coletadas de fontes públicas são um excelente recurso para a inteligência em segurança.

Porém, um dos maiores problemas da OSINT é uma sobrecarga de informações em potencial; filtrar a percepção do "ruído" pode ser difícil. De fato, sem ferramentas valiosas de OSINT, encontrar e pesquisar as informações corretas pode ser uma atividade demorada. A OSINT também não está pronta para uso; exige uma grande quantidade de trabalho analítico de seres humanos para distinguir informações válidas e verificadas de notícias e informações enganosas ou simplesmente imprecisas. Para aproveitá-la, é necessário uma análise detalhada e um entendimento dos requisitos para usá-la, uma vez que a OSINT não exclui a inteligência tradicional coletada de fontes confidenciais (ações de busca). A combinação de fontes OSINT e inteligência tradicional é uma abordagem poderosa.

Em relação à mentalidade de inteligência, quando um analista de inteligência iniciar sua pesquisa, precisará pensar em como localizar todos os dados necessários para chegar a uma determinada visão. É fundamental que ele considere o uso de certas fontes e ferramentas, além de pesá-las umas contra as outras para tomar decisões. É necessário manter os preconceitos pessoais fora do caso, pois eles fatalmente podem influenciar a pesquisa.

Levar em consideração os princípios da Inteligência é fundamental no trabalho de OSINT. Em todas as ações, o analista tem que fazer essas perguntas: Estou sendo objetivo? São essas as perguntas certas? Os dados fornecem tudo o que é necessário para responder à(s) pergunta(s)?

O pensamento crítico é fundamental para realizar uma pesquisa em OSINT. Tenha em mente que os dados coletados podem conter informações para enganá-lo, como notícias falsas, bots etc.; relatórios falsificados estão por toda a parte. As fontes que você usa são confiáveis e por que são consideradas de confiança?

13 METODOLOGIA PARA AÇÕES DE OSINT

Descreveremos a seguir a metodologia aplicada em ações de OSINT utilizada pelas principais agências de inteligência do mundo:

1. Escolha seu assunto de pesquisa de preferência, faça uma entrada com seu cliente e defina a(s) pergunta(s). Defina uma pergunta "respondível", por exemplo:

“Consiga-me tudo em Joãozinho”, não é respondível (o que é “tudo?”). “Joãozinho esteve na posição x com a pessoa y?” Isso, sim, é uma pergunta “respondível”.

2. Faça o dever de casa sobre o assunto (conheça seu cliente e seu adversário).

3. Defina a questão principal de pesquisa, preferencialmente com um subconjunto de perguntas. Utilize os 6 Ws:

- O quê (*What*)?
- Onde (*Where*)?
- Quando (*When*)?
- Qual método? (*Which method*)?
- Quem (*Who*)?
- Por quê (*Why*)?

4. Defina fontes (Google, X, Facebook, Instagram etc.).

5. Reúna palavras-chave em cada questão de pesquisa.

6. Pense quais ferramentas (OSINT) devem ser necessárias para essa pesquisa.

7. Faça uma pesquisa de verificação rápida (pesquisa de temporizador para evitar o afogamento em informações, quando você realmente começa a pesquisar).

8. As descobertas preliminares são o que você esperava encontrar? Caso contrário, repita os passos 1 ao 5.

9. Reúna as informações necessárias, esgotando suas fontes.

10. Refina e analise as informações encontradas.

11. As descobertas secundárias são o que você esperava encontrar? Caso contrário, repita os passos 1 ao 8.

12. Relatório: inclua tudo. As coisas que você encontrou e analisou e também as coisas que você não encontrou.

13. Deixe o relatório descansar, literalmente. Não o envie imediatamente.

14. Quando alguém voltar às suas conclusões/relatório com novas perguntas, repita todos os passos acima.

OSINT Mind Map

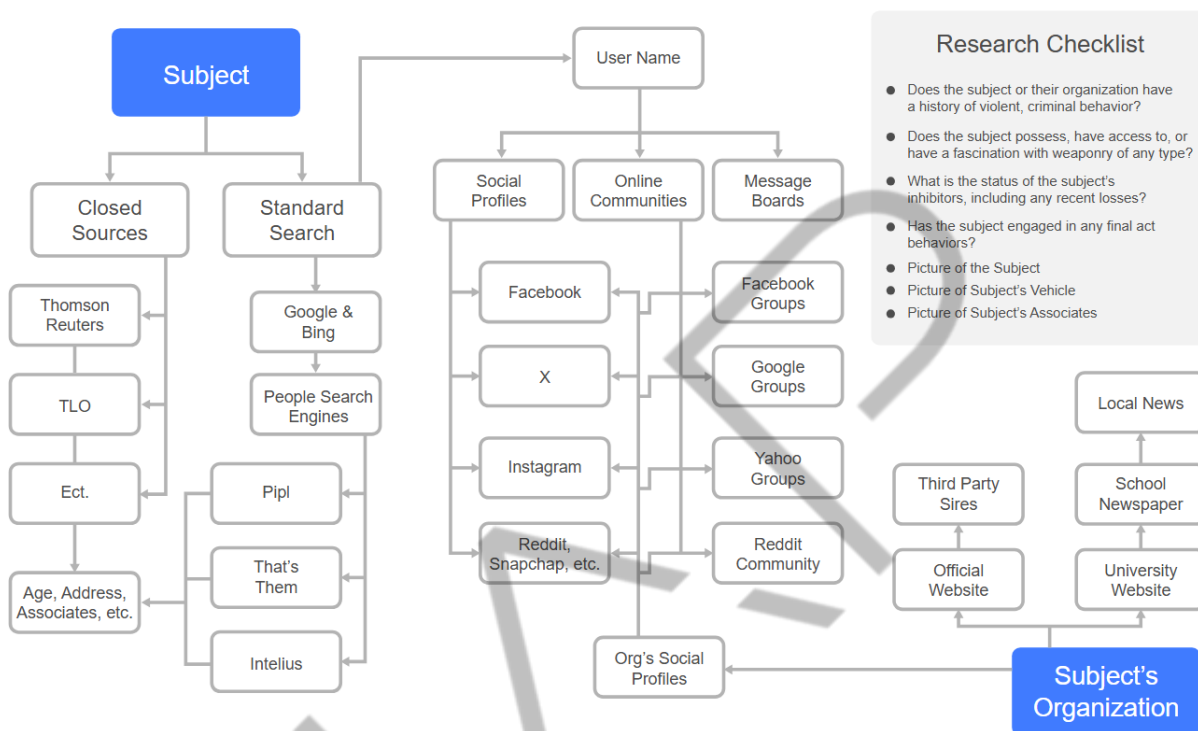


Figura 6 - Mindmap de ações em OSINT
Fonte: Adaptado por Fiap (2019)

14 OSINT E ANONIMIZAÇÃO

O primeiro princípio da inteligência é a segurança. É com base nesse aspecto que as ações de um analista de inteligência em operações em OSINT devem ser baseadas, tendo em vista que a segurança do analista (seus dados, identidade, localização etc.) deve ser resguardada a todo custo, inclusive em detrimento da ação de exploração.

Nesse contexto, é fundamental utilizar técnicas de anonimização em ações de OSINT, pois não apenas o alvo pode identificar o analista, mas também mecanismos de busca e sites que utilizam cookies podem rastrear e expor a identidade do investigador. Além disso, como vimos anteriormente, por meio da correlação de tráfego, o *fingerprint* do analista pode ser detectado se a anonimização não for feita da forma correta.

Outro ponto importante nas ações de OSINT, levando em conta a anonimização, é a utilização de perfis *fake*. Redes sociais utilizam o *fingerprint* do usuário para, dentre outros motivos, fornecer o conteúdo publicitário direcionado ao seu perfil. Do ponto de vista da segurança, isso é perigoso, pois a identidade digital do usuário está sendo compartilhada entre a rede social e seus parceiros comerciais. Um exemplo notório desse risco foi o vazamento de dados envolvendo o Facebook, como no caso da *Cambridge Analytica*, em 2018, em que informações pessoais de milhões de usuários foram acessadas sem o seu consentimento para fins de manipulação política.

Diante disso, um analista de OSINT deve tomar o cuidado de utilizar perfis falsos para a realização de suas ações exploratórias, além dos cuidados de anonimização de sua conexão. Esses perfis precisam ser criados com extremo cuidado para garantir que, em hipótese alguma, possam ser rastreados até o analista em caso de auditorias de segurança ou análises forenses.

15 TOP 5 FERRAMENTAS DE OSINT

Para um analista de inteligência, ter ferramentas confiáveis e que automatizem seu trabalho é fundamental. Elencaremos a seguir as cinco principais ferramentas *Open Source* para ações de análise e busca.

1) Maltego

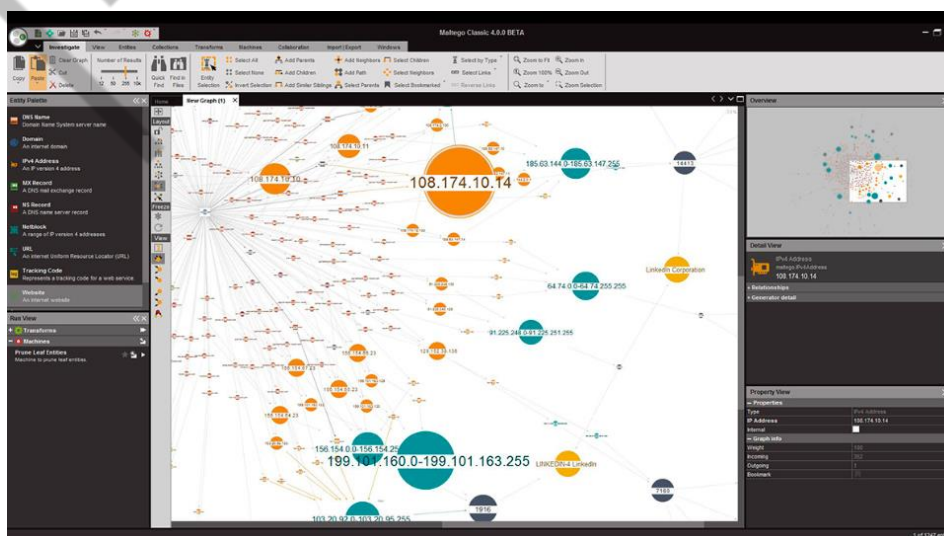


Figura 7 - Maltego
Fonte: Google Imagens (2019)

É um programa que recolhe informações de várias fontes abertas e relaciona os dados recolhidos. Possui várias vertentes, desde as análises de DNS, como engenharia social, passando por um excelente relacionamento dos dados. O Maltego é uma plataforma única que mostra, de uma maneira muito simples, transparente e fácil, todo o ambiente de uma organização/rede.

Abaixo citamos alguns tipos de dados que podem ser coletados e relacionados por meio dessa ferramenta:

- Pessoas.
- Grupos de pessoas/redes.
- Companhias.
- Organizações.
- Websites.
- Nomes de DNS.
- Blocos de AS.
- Endereços de IP.
- Palavras-chave.
- Associações.
- Arquivos.
- Entidades que estão relacionadas em fontes públicas.

É fácil de instalar e rodar em Windows, Mac e Linux (já vem por padrão no Kali Linux). Além disso, apresenta os resultados de forma gráfica, permitindo visualizar facilmente as relações entre os dados.

2) Recon-NG



Figura 8 - Recon-NG
Fonte: Google Imagens (2019)

É uma estrutura de reconhecimento web repleta de recursos e escrita em Python, já presente por padrão no Kali Linux. Completo com módulos independentes, interação com o banco de dados, funções de conveniência integradas, ajuda interativa e execução de comandos, o Recon-ng oferece um ambiente poderoso no qual o reconhecimento web pode ser conduzido de maneira rápida e completa.

O Recon-ng tem uma aparência semelhante ao *Metasploit Framework*, mas apresenta um propósito bem diferente: se quiser explorar, use o *Metasploit Framework*; se você for engenheiro social, use o *Social-Engineer Toolkit*; se você quiser realizar reconhecimento, use o Recon-ng.

3) The Harvester



Figura 9 - The Harvester rodando o Kali Linux
Fonte: Google Imagens (2019)

O objetivo dessa ferramenta é coletar e-mails, subdomínios, hosts, nomes de funcionários, portas abertas e banners de diferentes fontes públicas, como mecanismos de busca, servidores de chaves PGP e banco de dados de computador SHODAN.

Ela destina-se a ajudar os *pentesters* nos estágios iniciais do teste de penetração, a fim de compreender o *fingerprint* do alvo na Internet. Também é útil para qualquer pessoa que queira saber o que um invasor pode ver sobre sua organização.

4) Shodan

É o primeiro serviço de busca que permite encontrar computadores e dispositivos conectados à rede, como webcams, roteadores domésticos e empresariais, smartphones, tablets, telefones VoIP, servidores, sistemas de videoconferência e até outros, como monitores de bebê e sistema de refrigeração de um prédio.

Além de informações sobre esses dispositivos, ele recolhe informações sobre servidores HTTP, FTP, SSH, Telnet, SNMP, SIP etc.

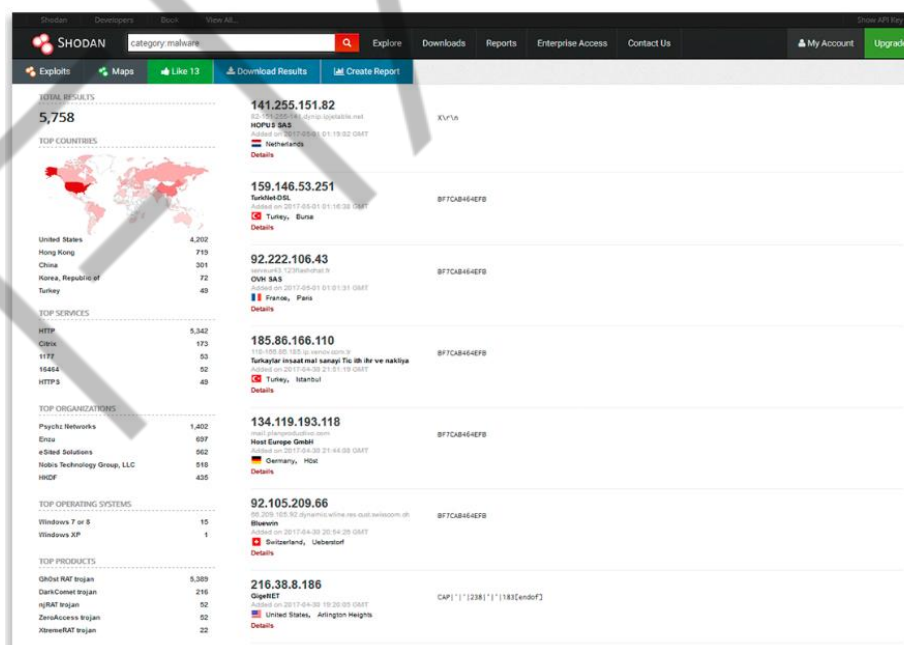


Figura 10 - Shodan
Fonte: <https://www.shodan.io/> (2019)

Um relato interessante sobre o Shodan foi postado no blog CanalTech e aconteceu com Marc Gilbert, que teve uma terrível surpresa em seu aniversário de 34 anos. Depois da festa acabar, ele ouviu uma voz nada familiar vinda do quarto de sua

filha de dois anos dizendo *Wake up, you little slut*. Quando Marc chegou ao quarto, ele descobriu que a voz vinha do monitor de bebê e que alguém havia tomado controle do aparelho, sendo capaz até de manipular a câmera. Gilbert imediatamente desligou o monitor da tomada, mas não antes de o hacker chamá-lo de idiota.

O monitor usado por Marc permitia monitorar áudio e vídeo pela internet de qualquer lugar do mundo, e é bastante utilizado por pais que querem vigiar o que está acontecendo com seus filhos em casa, enquanto estão longe. Marc disse que processaria a Foscam, fabricante do eletrônico, mas talvez o verdadeiro culpado tenha sido John Matherly, o criador do Shodan.

Essa situação ocorreu pois o monitor da filha de Marc estava conectado à internet e possuía credenciais de acesso do padrão de fábrica (um provável admin/admin). Com isso, o atacante não precisou de muito para acessar o dispositivo e “brincar” com Marc.

5) Google Hacking e Google Dorks

O *Google Hacking* nada mais é que uma prática para encontrar arquivos e/ou falhas a partir do Google, usando-o como uma espécie de scanner, dando comandos e possibilitando manipular buscas avançadas por *strings*, chamadas de “*dorks*” ou “operadores de pesquisa”. Por intermédio das *dorks*, praticamente tudo o que está disponível na internet pode ser buscado pelo Google, bastando apenas saber passar os parâmetros corretos ao Google.

Seguem alguns exemplos de dorks:

- *Intitle*: procura as palavras mencionadas no título da página.
- *Inurl*: procura as palavras mencionadas no URL.
- *Filetype*: é usado para encontrar tipos de arquivos.
- *Ext*: é usado para identificar arquivos com extensões específicas. Pense em utilizá-lo para encontrar arquivos como .log, que não devem ser indexados.
- *Intext*: ajuda a procurar um texto específico na página.

O universo das *dorks* vai muito além disso e ainda é atualizado constantemente pelo Google. Aqui estão algumas dicas de sites e repositórios que mantêm atualizadas as informações sobre as *dorks*:

- *New Google Dorks List Collection for SQL Injection 2023:*

<https://gbhackers.com/latest-google-sql-dorks/#google_vignette>

- *1000 Best Google Dorks List (Google Hacking Guide) – 2024:*

<<https://gbhackers.com/latest-google-dorks-list/>>

- *List of 1100 +Google Dorks 2024: A complete sheet of dorks:*

<<https://itechhacks.com/google-dorks-list/>>

16 LAB

Nesse LAB iremos colocar em prática nosso aprendizado sobre anonimização e OSINT.

16.1 Contexto

Você, analista de inteligência da polícia da cidade de São Paulo, recebeu a tarefa de efetuar uma coleta em fontes abertas sobre um determinado alvo. Sua missão é coletar o máximo de informações possíveis sobre esse alvo. Porém, o objetivo maior é o contato de e-mail dele.

16.2 Informações iniciais sobre o alvo

- Nome: Sérgio Lopes.
- Facebook: <<https://goo.gl/7MDGpc>>.

16.3 Condução do LAB

1. Em uma máquina Windows, iremos realizar o download do *Tor Browser* no site do projeto

<<https://www.torproject.org/projects/torbrowser.html.en#windows>> e depois iremos iniciar a instalação seguindo os passos a seguir:

- a) Faça o download do instalador, salve-o em algum lugar e clique duas vezes nele. Clique em "Executar", escolha seu idioma e clique em OK. Certifique-se de ter pelo menos 80 MB de espaço livre em disco no local selecionado. Se você quiser deixar o pacote no computador, salvá-lo na área de trabalho é uma boa escolha. Se você quiser movê-lo para outro computador ou limitar os rastros que você deixou, salve-o em um disco USB.
- b) Clique em "Instalar" e aguarde até o instalador terminar. Isso pode levar alguns minutos para ser concluído.

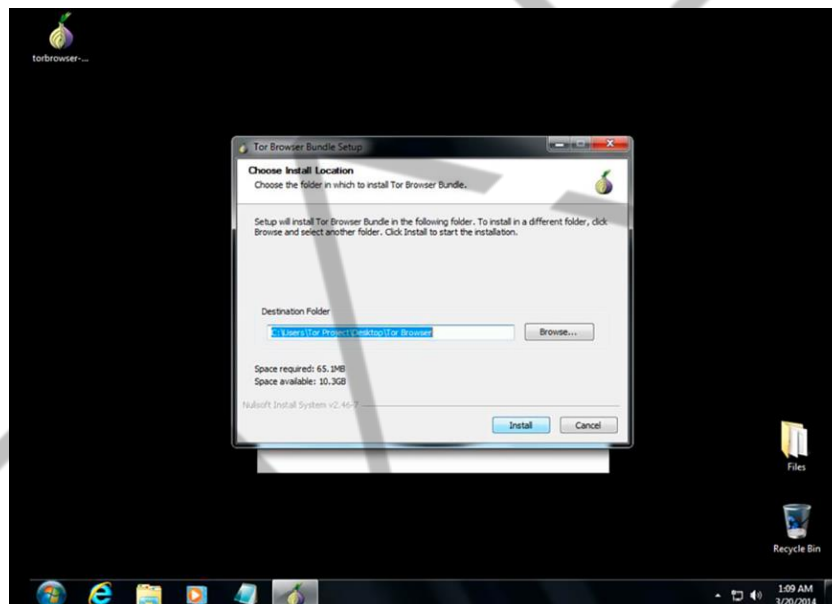


Figura 11 - Extração do *Tor Browser*
Fonte: Tor Project (2019)

- c) Quando a instalação estiver concluída, clique em "Concluir" para iniciar o assistente do *Tor Browser*.
- d) Depois de ver o assistente do *Tor Browser*, clique em "Conectar".
- e) Alternativamente, você pode iniciar o navegador *Tor* acessando a pasta "Navegador Tor", que pode ser encontrada no local em que você salvou o pacote em "Padrão: Desktop". Clique duas vezes no aplicativo "*Start Tor Browser*".

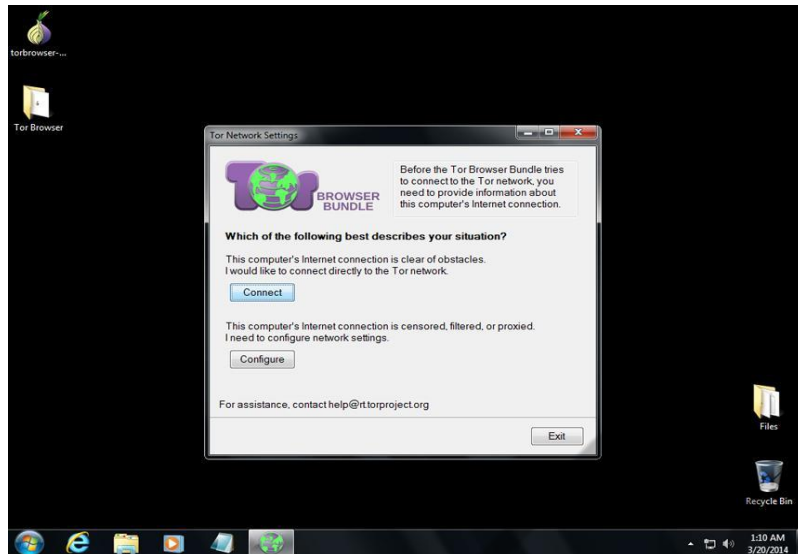


Figura 12 - Conectando na Rede Tor
Fonte: Tor Project 2019)

- f) Quando o *Tor* estiver pronto, o navegador *Tor* será aberto automaticamente. Apenas as páginas da web visitadas pelo *Tor Browser* serão enviadas via *Tor*. Outros navegadores da web, como o *Internet Explorer*, não são afetados.
- g) Quando terminar de navegar, feche todas as janelas abertas do navegador *Tor* clicando no botão “Fechar (x)”. Por motivos de privacidade, a lista de páginas da web visitadas e os cookies serão excluídos.

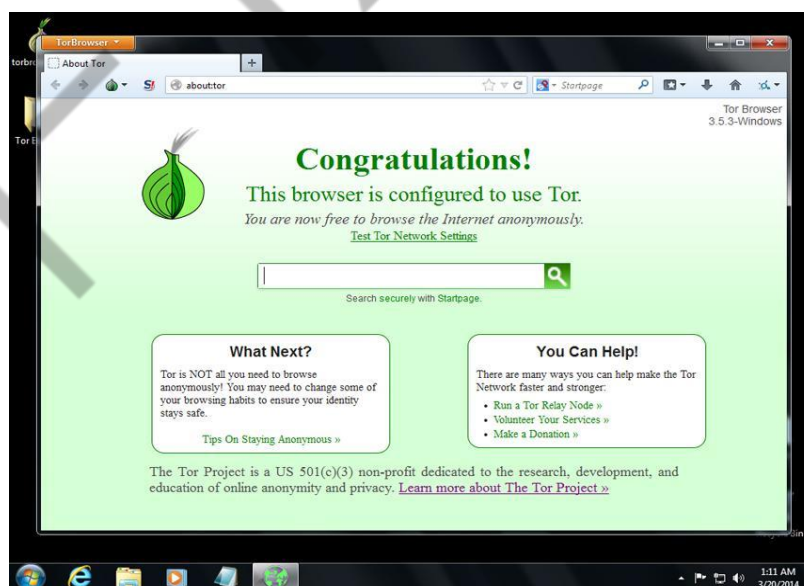


Figura 13 - Usando o Tor Browser
Fonte: Tor Project (2019)

- h) Para usar o navegador *Tor* novamente, clique duas vezes no aplicativo "*Start Tor Browser*".
2. Após a instalação do *Tor Browser*, acesse o perfil do alvo e obtenha as informações que estão disponíveis.
 3. Agora, utilizando o *Tor Browser*, crie um e-mail *fake* no serviço de e-mail que desejar e crie também uma conta *fake* no Facebook.
 4. Feito isso, acesse novamente o perfil do alvo e veja se consegue mais alguma informação que não estava disponível antes de se conectar à rede social.
 5. Agora, utilizando as técnicas de *Google Hacking*, realize buscas no Google com o e-mail que você conseguiu capturar do alvo no Facebook, a fim de saber se existem outros locais na internet em que o alvo possua conta ou que ele seja citado. Tente realizar buscas simples, utilizando aspas duplas ao redor do endereço de e-mail do alvo e vá incrementando sua busca utilizando as *dorks intext* e *inurl*.

REFERÊNCIAS

MENDES, Diogo Carvalho. **Técnicas de hacking para anonimização na Internet**. 2014. Disponível em: <<https://repositorio.ucp.pt/handle/10400.14/15325>>. Acesso em: 02 dez. 2024.

VAZ, Asael da Silva. **Proposta de procedimentos para anonimização da origem de ataques cibernéticos**. Trabalho de Conclusão de Curso (Especialização em Ciências Militares com ênfase em Gestão Organizacional). Escola de Aperfeiçoamento de Oficiais, Rio de Janeiro, 2018. Disponível em: <https://bdex.eb.mil.br/jspui/bitstream/1/2642/1/Tcc_Com_Cap_Asael.pdf>. Acesso em: 02 dez. 2024.